

Module Code & Module Title

CP70044E Security Operation and Assurance

Assessment Weightage & Type

50% Individual Assessment

Student Name: Sagar Gurung

Student ID: 33147045

Programme: MSc Software Engineering

Assessment Title: Security Operations and Assurance Assignment I

Table of Contents

1. Introduction..... 1
2. Network Inventory..... 2
2.1 Virtual Network Overview..... 2
2.2 Kali Linux (Attacker Machine)..... 3
2.3 Metasploitable 2..... 5
2.4 Windows 10 with WebGoat..... 6
2.5 DVWA (Custom Target System)..... 7
2.6 Network Inventory Summary..... 8
3. Methodology And Command..... 9
3.1 Network Host Discovery..... 9
3.2 Port Scanning..... 9
3.3 Service and Version Detection..... 10
3.4 Vulnerability Scanning Using OpenVAS..... 10
4. Scanning Results & Evidence..... 11
4.1 Host Discovery Results..... 11
4.1 Nmap Port and Service Scanning Results..... 12
4.1.1 Metasploitable 2 – Nmap Results..... 12
4.1.2 Windows 10 with WebGoat – Nmap Results..... 13
4.1.3 DVWA Virtual Machine – Port and Service Scan Summary..... 15
4.3 OpenVAS Vulnerability Scanning Results..... 16
4.3.1 Metasploitable 2 – OpenVAS Results..... 17
4.2.3 Windows 10 with WebGoat – OpenVAS Results..... 19
4.2.3 DVWA Virtual Machine – OpenVAS Results..... 21
5. Vulnerability Analysis & Mitigation..... 23
5.1 Vulnerability Description – rlogin Passwordless Login..... 23
5.2 Potential Impact..... 24
5.3 Exploitation Overview..... 24
5.4 Mitigation and Recommendations..... 25
5.5 Relevance to SOA Enterprises, Inc..... 25
6. Incident Response Considerations..... 27
7. Legal, Ethical and Professional Considerations..... 27
8. Conclusion..... 28
9. References..... 29

List of Screenshots

1. Environment Setup for Testing in VirtualBox …… 3
2. Kali Linux (Attacker) …….. 4
3. Kali Linux IP Config Details …….. 4
4. Metasploitable 2 Login …….. 5
5. Metasploitable 2 IP Config Details …….. 5
6. Windows 10 Home Screen …….. 6
7. Windows 10 IP Config Details ……. 6
8. WebGoat Running in Windows 10 ……. 7
9. DVWA IP Config Details …….. 8
10. Host Discovery Results …… 11
11. Metasploitable 2 Port and Service Scan From Kali Linux …….. 13
12. Windows 10 Port and Service Scan From Kali Linux ……. 14
13. Windows 10 Firewall Activation Details …… 15
14. DVWA Port and Service Scan From Kali Linux …….. 16
15. OpenVas Running in Kali Linux ……. 17
16. Metaspliotable 2 Vulnerability Scan with OpenVas Report …….. 18
17. Metaspliotable 2 Vulnerability Scan with OpenVas Result …… 19
18. Windows 10 Vulnerability Scan with OpenVas Report …….. 20
19. Windows 10 Vulnerability Scan with OpenVas Result …….. 20
20. DVWA Vulnerability Scan with OpenVas Report …… 22
21. DVWA Vulnerability Scan with OpenVas Result ……. 22
22. Most Critical Vulnerability from overall scan with OpenVas ……. 24
23. Overall Vulnerabilities from overall scan with OpenVas within 3 systems ……. 26
24. Overall Vulnerabilities from overall scan with OpenVas within 3 system Result 26

List of Tables

1. Network Inventory Summary 10
2. Host Discovery Result 13
3. Vulnerability Severity Summary for Metaspliotable 2 19
4. Vulnerability Severity Summary for DVWA 22

1. Introduction

Computer systems and web applications have become pivotal towards supporting daily business operations of modern organisations. Although these technologies enhance productivity and access, they also give loopholes to cyber attackers who can misuse the weak points provided that systems are not secured adequately. Cyber attacks may also target even small businesses and result in a data leak, disruption of service, loss of money, or even in negative publicity (Stallings, 2018). This is why cyber security risks should be comprehended and controlled by organisations of every scale.

Penetration testing is both realistic and a legitimate method of verifying the levels of security of the systems of an organisation. It includes the process of testing the systems safely in a controlled space to detect the weak points during which the attackers cannot exploit them. Instead of waiting until the actual cyber attack takes place, penetration testing enables organisations to discover weaknesses in security early and act to rectify (Scambray, McClure and Kurtz, 2011). This will contribute to mitigating risk and enhancing trust in the general security posture of the organisation.

The simulated environment of a small-business is SOA Enterprises, Inc. upon which this assignment is founded. The organisation has been assumed to have a standard IT infrastructure consisting of windows and Linux, and in-house web applications. Certain of these systems are known to have security weaknesses, which is realistic as systems can be either poorly configured or old-fashioned or they can lack protection. This assessment is meant to determine the vulnerability of these systems and the way an attacker can seek to take advantage of them (OWASP, 2021).

The primary goals of this penetration testing exercise are to find out which systems are operational within the network, which services are operational within those systems and any security vulnerabilities that may cause a threat to the organisation Lyon, 2024; Greenbone, 2023). Special focus is made on those vulnerabilities that may lead to a severe effect, including the provision of unauthorised access or control to systems.

Moreover, the task will consider the level of preparedness of SOA Enterprises, Inc. regarding response in case of a security crisis (NIST, 2018).

In order to perform this evaluation, a safe laboratory was developed by using virtual machines. The testing platform was **Kali Linux**, and a set of vulnerable systems were setup to simulate the infrastructure of the organisation, they consisted of a Linux-based server which include **Metasploitable 2**, a deliberately vulnerable Linux system designed to demonstrate common service-level weaknesses, **a Windows 10 system with an intentionally vulnerable web application (WebGoat)**, and a custom system of **Damn Vulnerable Web Application (DVWA)**. The structured and ethical analysis of these systems was then provided with the help of industry-standard security tools.

On the whole, this penetration testing exercise shows how the security vulnerabilities may be detected and addressed before being used by actual attackers. Based on the evaluation of technical outcomes, as well as incident response readiness and legal and ethical responsibility, the report will reveal the importance of proactive security testing in the protection of organization systems and data.

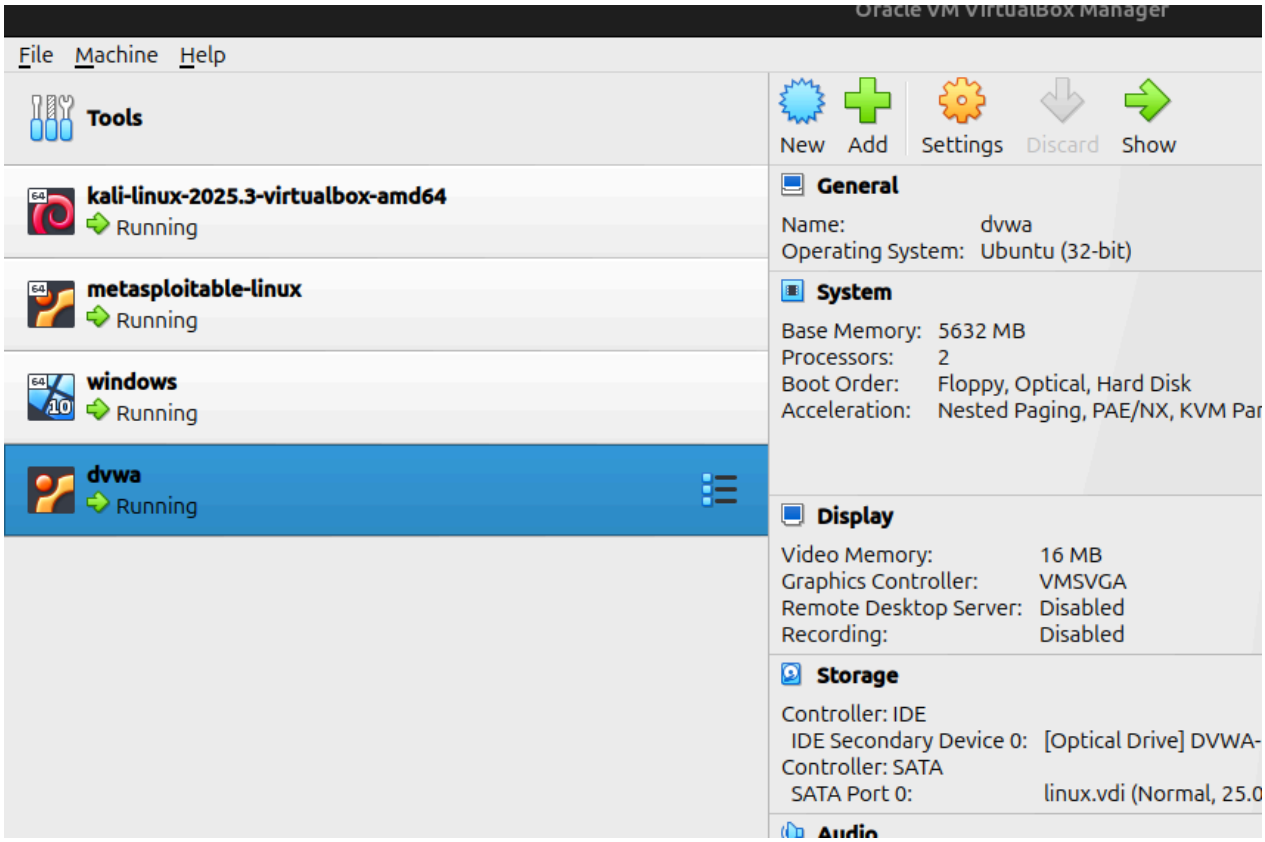
2. Network Inventory

This section describes the systems that were incorporated in the penetration testing environment of SOA Enterprises, Inc. Oracle VirtualBox was used to deploy the network so that all the virtual machines were connected to a common internal network to enable communication and they were isolated to the external systems. With this control setup, we are sure that no testing would have been performed in an unethical manner.

2.1 Virtual Network Overview

The two components of the network environment are one attacker machine and several vulnerable target systems. The reconnaissance and vulnerability scanning is done on the attacker machine and the target systems are typical organisational

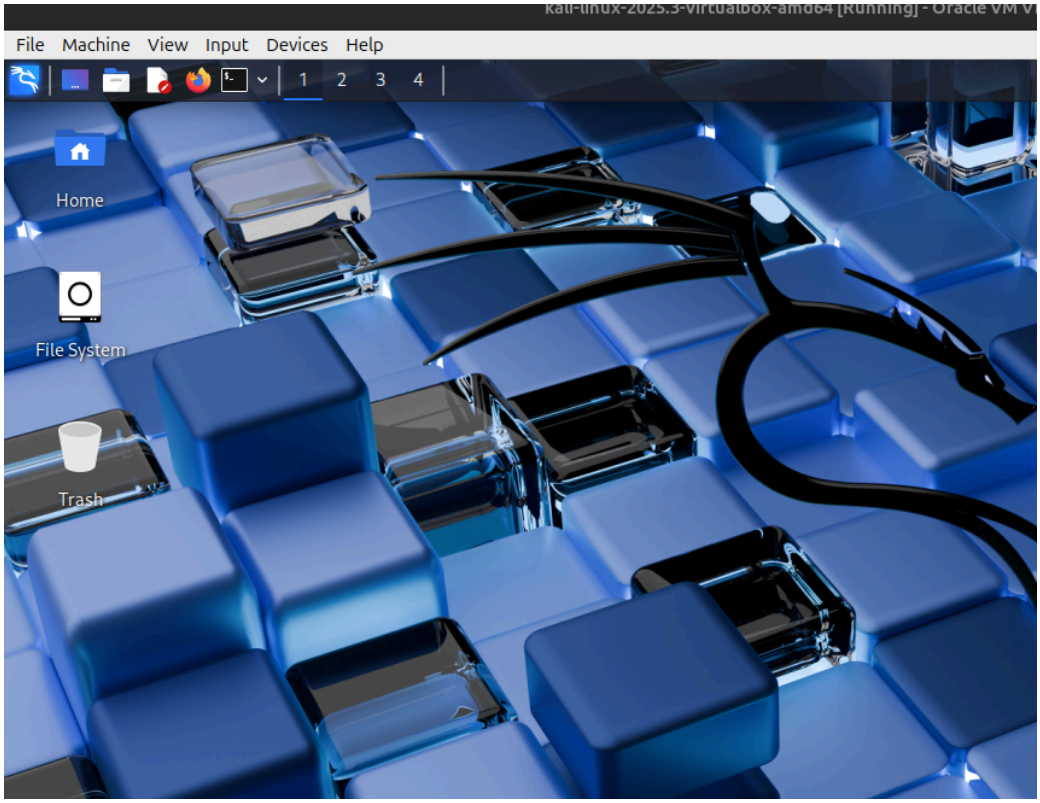
resources and are known to have security vulnerabilities. The environment has Windows and Linux systems, which are used to represent a realistic business infrastructure.



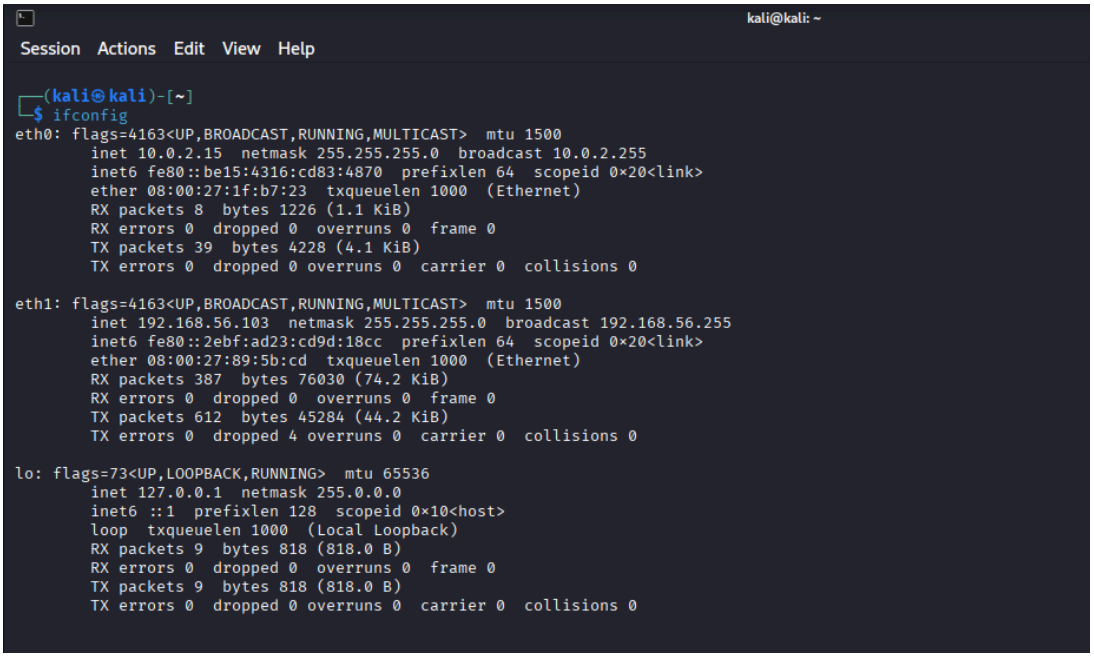
SS1: Environment Setup for Testing in VirtualBox

2.2 Kali Linux (Attacker Machine)

Kali Linux is used as the attacker system within the network. It hosts industry-standard penetration testing tools, including **Nmap** and **OpenVAS**, which are used to identify active hosts, open ports, and known vulnerabilities.



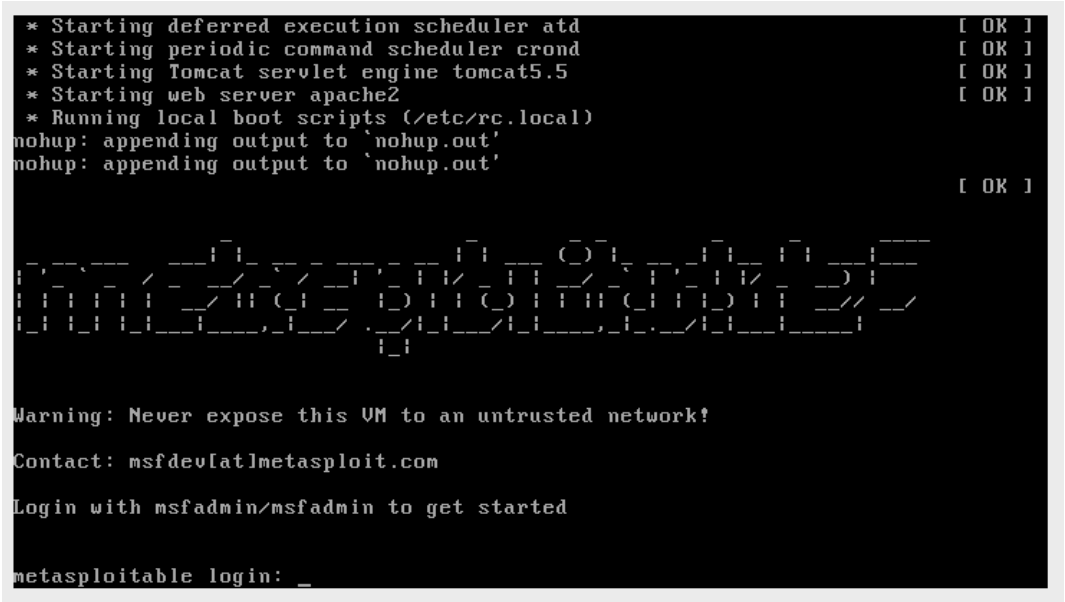
SS2: Kali Linux (Attacker)



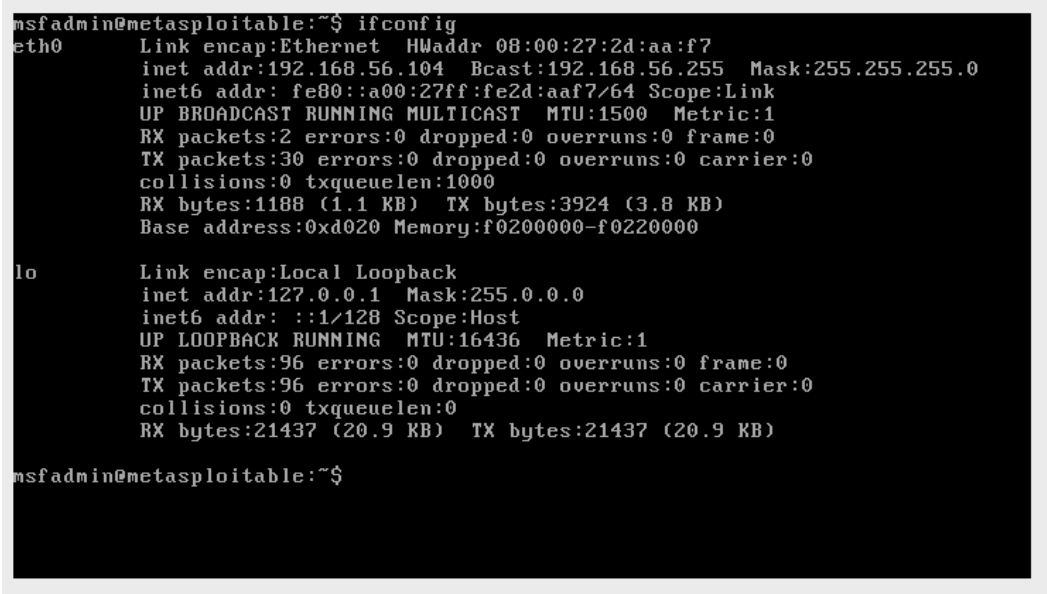
SS3: Kali Linux IP Config Details

2.3 Metasploitable 2

Metasploitable 2 is a deliberately vulnerable Linux server designed for penetration testing. It simulates an insecure internal server with multiple exposed services, allowing the assessment of service-level vulnerabilities.



SS4: Metasploitable 2 Login



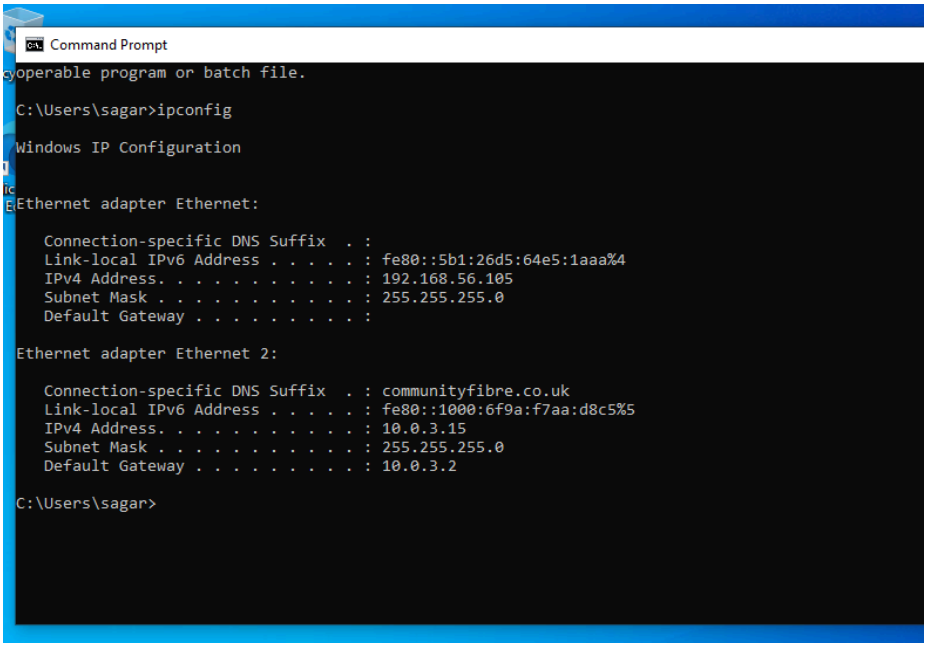
SS5: Metasploitable 2 IP Config Details

2.4 Windows 10 with WebGoat

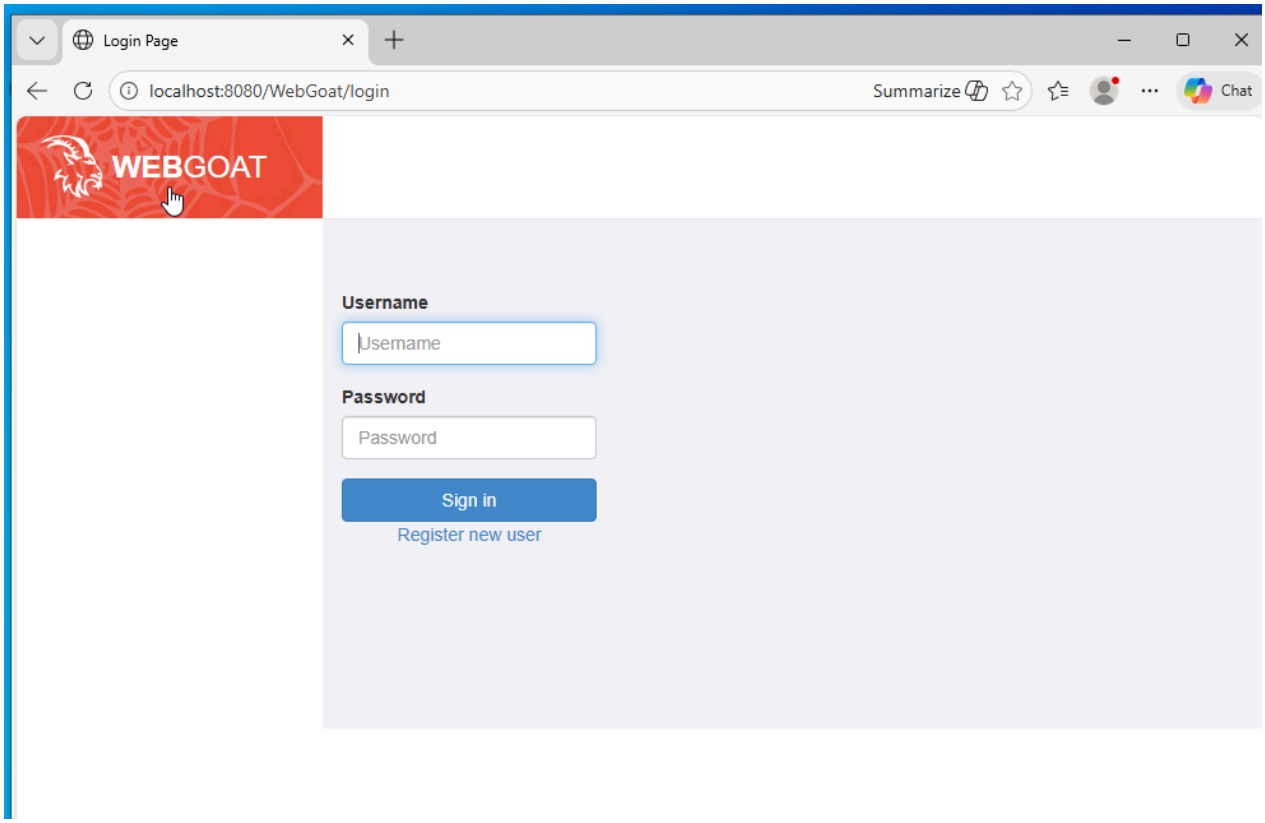
The Windows 10 VM is a virtual machine, a user workstation that is running the insecure web application, WebGoat. This system is employed in analysing typical web application security vulnerabilities.



SS6: Windows 10 Home Screen



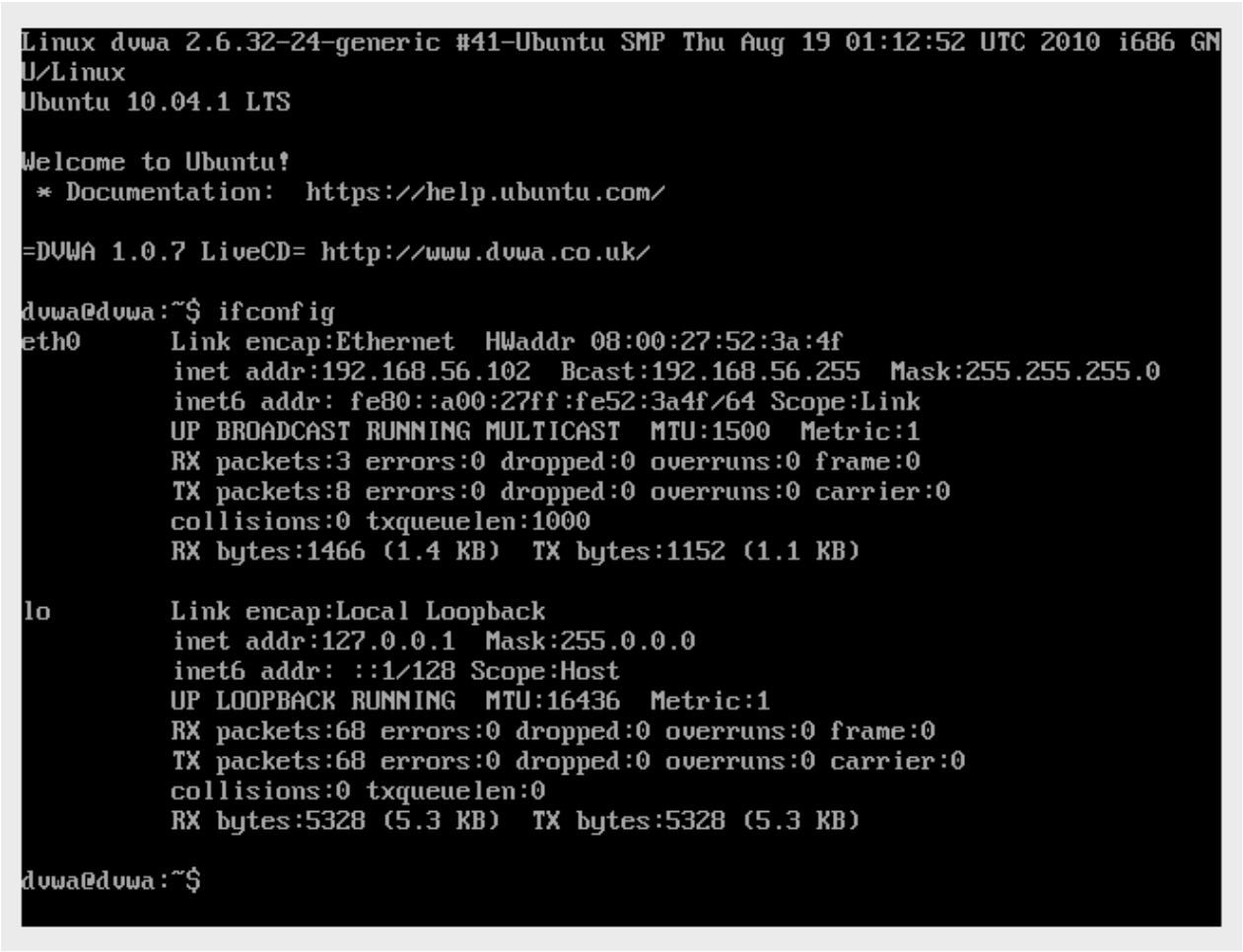
SS6: Windows 10 IP Config Details



SS8: WebGoat Running in Windows 10

2.5 DVWA (Custom Target System)

DVWA virtual machine is the custom Linux environment that contains Damn Vulnerable Web Application (DVWA). It is added to expand the sphere of the assessment and to show more vulnerabilities of web application.



SS9: DVWA IP Config Details

2.6 Network Inventory Summary

Device Name	Operating System	IP address	What is it for?
Kali	Linux	192.168.56.100	**The Attacker:** My main computer used for testing.
Metasploitable 2	Linux	192.168.56.103	**Target 1:** A Linux server full of security holes.
Windows 10 (WebGoat)	Windows	192.168.56.105	**Target 2:** A regular office PC running the WebGoat app.

DVWA	Linux	192.168.56.102	**Target 3:** A special website made for hacking practice.

Table 1: Network Inventory Summary

3. Methodology And Command

This paragraph provides the methodology of undertaking the penetration testing exercises on SOA Enterprises, Inc. This section will aim to outline the tools and techniques that were used in the course of the assessment, and how network reconnaissance and vulnerability scanning were conducted in a reasonably and ethically organized way. The testing was done all through the Kali Linux attacker machine in a controlled virtual laboratory environment.

3.1 Network Host Discovery

The initial phase of the penetration testing process entailed the process of identifying active hosts in the internal network. Host discovery was conducted to find out which systems could be accessed and were to be mentioned in the scope of further testing. Scanning of the internal network was done with Nmap to identify live systems without scanning the ports. Nmap (Network Mapper) is a popular network scanning program that is intended to identify running services, active ports, and hosts on a network. It aids security team members to know the exposure of networks by determining the available systems and the services they render, which is a core tool of network reconnaissance in penetration testing (Lyon, 2024).

Command used: `nmap -sn 192.168.56.0/24`

3.2 Port Scanning

Following the identification of active hosts, port scanning was performed so as to identify the ports of the target systems that are open. Full TCP port scan of each target machine was done to identify all the services that are exposed to possible security risks in case of misconfigurations or outdated services.

Command used: `nmap -p- 192.168.X.X`

3.3 Service and Version Detection

After the identification of the open ports, service and version detection were performed to provide more information about the services operating on the ports. Service version identification Service and versions identification on the identified open ports were performed with nmap.

Command used: `nmap -sV 192.168.X.X`

3.4 Vulnerability Scanning Using OpenVAS

OpenVAS was utilized to perform automated scanning of vulnerabilities in the target systems in order to determine known security weaknesses of the systems. Open Vulnerability Assessment System (OpenVAS), is a free vulnerability scanning engine applied to detect the known security vulnerabilities within networked systems. It compares the exposed service and configurations with an up-to-date vulnerability database and classifies the results according to the level of seriousness that enables organisations to rank security threats (Greenbone, 2023). OpenVAS analyses identified services and configurations by comparing the services and configurations to a large database of vulnerabilities. Complete scanning of the targeted machines was conducted against the selected target machines and the obtained results were tabulated according to the levels of severity including low, medium, and high. These were later used to support vulnerability analysis and risk assessment.

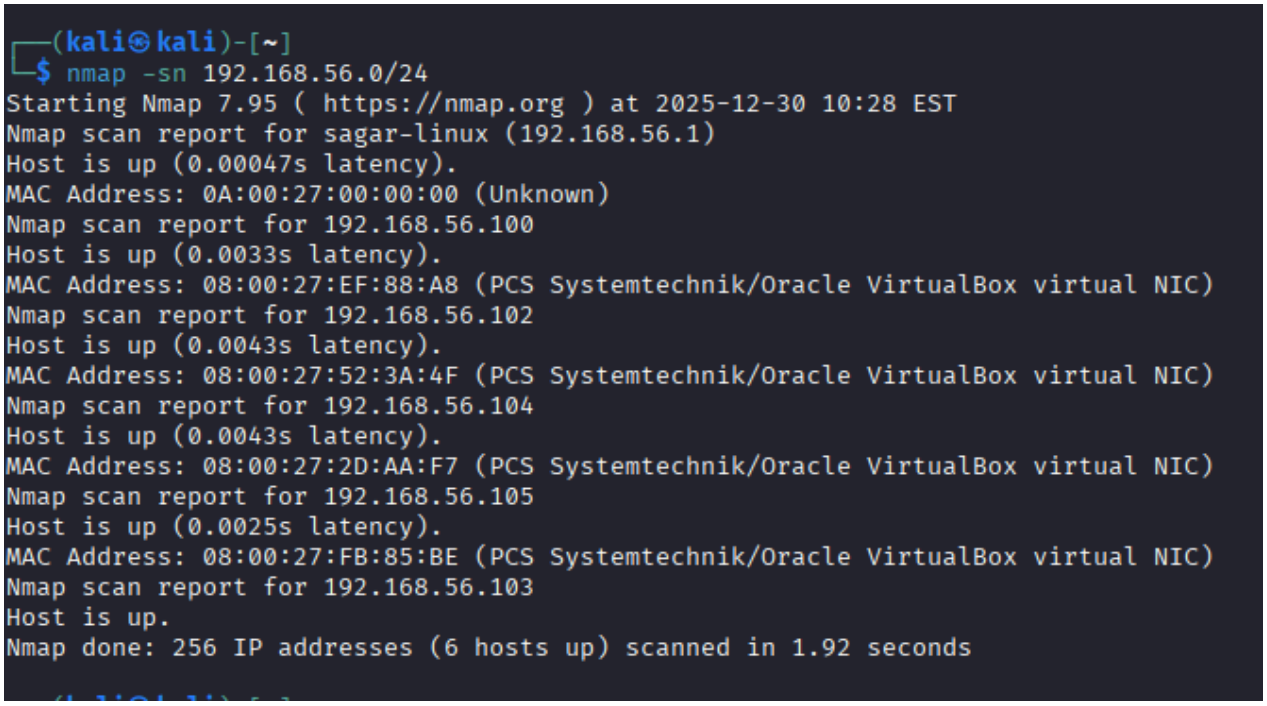
The procedure that is taken during this assessment is a systematic and ethical penetration testing. With Nmap to discover the network and identify the services and OpenVAS to scan vulnerability, the assessment will offer a methodological technique of determining possible areas of vulnerability within the SOA Enterprises, Inc. network.

4. Scanning Results & Evidence

The results of the activities carried out in the SOA Enterprises, Inc. network in which network scanning and vulnerability assessments were conducted are presented in this section. Nmap scans for host discovery, port and service identification, and OpenVAS vulnerability scans were used to get the results. The findings are supported by evidence in the form of scan outputs and screenshots.

4.1 Host Discovery Results

The host discovery scan has scanned the internal network to detect a few live systems, out of which these systems got confirmed as authorized targets defined in the network inventory.



SS10: Host Discovery Results

Discovered Hosts on Internal Network:

IP Address	Description
192.168.56.103	Kali Linux (Attacker machine)
192.168.56.104	Metasploitable 2
192.168.56.105	Windows 10 (WebGoat)
192.168.56.102	DVWA Virtual Machine

Table 2: Host Discovery Result

4.1 Nmap Port and Service Scanning Results

Port and service scanning was executed on every target machine in order to spot exposed services. For better understanding, the results for each system are shown individually.

4.1.1 Metasploitable 2 – Nmap Results

The Metasploitable 2 system (192.168.56.104) underwent a complete TCP port scan that included service and version detection. The scan disclosed a vast number of open ports which implied that a number of services were exposed and insecure. Out of the insecure services, most were old and frequently linked with known vulnerabilities, thus emphasizing the deliberately vulnerable characteristic of the system.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV 192.168.56.104
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-30 10:47 EST
Nmap scan report for 192.168.56.104
Host is up (0.0013s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
53/tcp    open  domain      ISC BIND 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec        netkit-rsh rexecd
513/tcp   open  login       OpenBSD or Solaris rlogind
514/tcp   open  shell       Netkit rshd
1099/tcp  open  java-rmi    GNU Classpath grmiregistry
1524/tcp  open  bindshell   Metasploitable root shell
2049/tcp  open  nfs         2-4 (RPC #100003)
2121/tcp  open  ftp         ProFTPD 1.3.1
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc         VNC (protocol 3.3)
6000/tcp  open  X11         (access denied)
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
48093/tcp open  java-rmi    GNU Classpath grmiregistry
50413/tcp open  status      1 (RPC #100024)
58847/tcp open  nlockmgr    1-4 (RPC #100021)
59142/tcp open  mountd      1-3 (RPC #100005)
MAC Address: 08:00:27:2D:AA:F7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

SS11: Metasploitable 2 Port and Service Scan From Kali Linux

Key Observation:

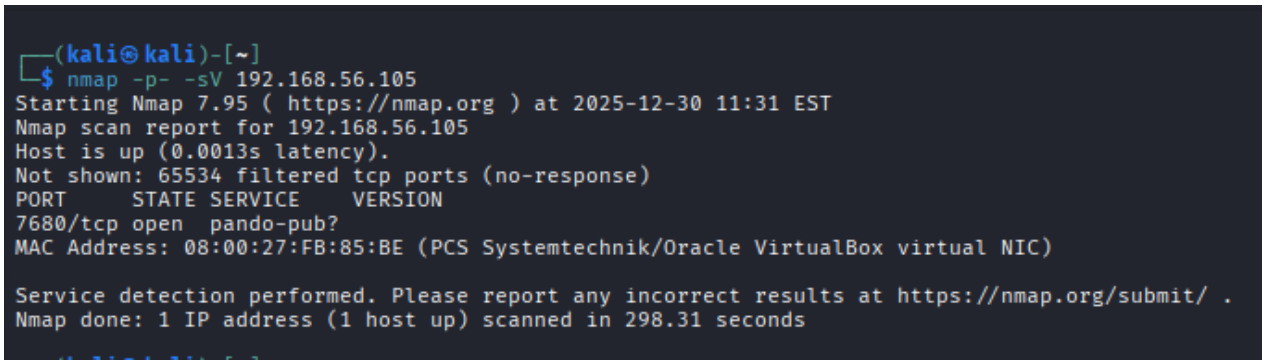
- It was discovered that over 30 open TCP ports are present in total.
- There are a number of old and insecure services that are still running, like FTP, Telnet, and r-services
- The existence of a bind shell on port 1524 is a serious violation of the security policy.
- Some of the services are not updated, thus the risk of exploits is high
- The system reveals vulnerabilities for both network and application attacks.

4.1.2 Windows 10 with WebGoat – Nmap Results

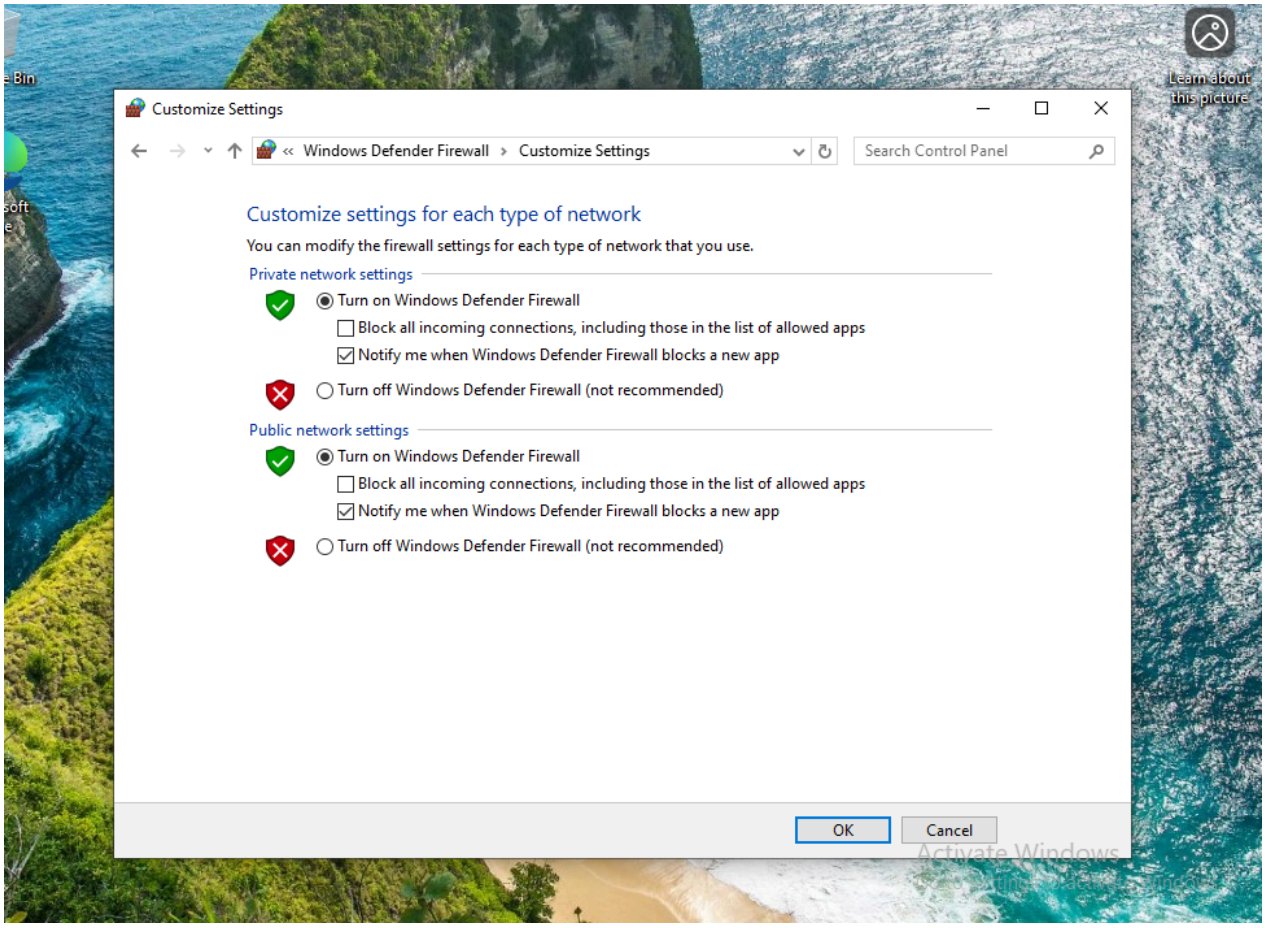
The Nmap port and service scan conducted on the Windows 10 system showed a very limited network exposure. The scan indicated that most of the TCP ports were filtered, which signifies that there were host-based firewall rules that restricted the access of the

external network to the system. Only a single TCP port 7680, and that being Windows services generally and not user applications, was left open. Ports for web services, like 8080, were also not identified during the scan despite the WebGoat application being confirmed as operational on the system.

These findings mean that the Windows firewall and network settings have done a great job in reducing the risk of external attacks through the lockdown of most services to inbound connections. Yet, the small amount of network-level exposure does not eliminate the risks coming from the WebGoat application that is still open to attacks if the intruder gets local or internal access. The findings of the study highlight how important it is to adopt security measures at the network and application levels simultaneously.



SS12: Windows 10 Port and Service Scan From Kali Linux



SS13: Windows 10 Firewall Activation Details

4.1.3 DVWA Virtual Machine – Port and Service Scan Summary

An Nmap port and service scan performed on the DVWA virtual machine showed that only a few TCP ports were open, all of which were related to web and database services. The FTP port was 21, and the SSH port was 22. However, these services can certainly be a vulnerability in security if not well set up or if they are running very old versions. The web services using the Apache HTTP server were considered to be connected with ports 80 and 443. The hosting application for the Apache server is the Damn Vulnerable Web Application. Moreover, a MySQL server on port 3306 indicates that there is a backend database supporting the web app.

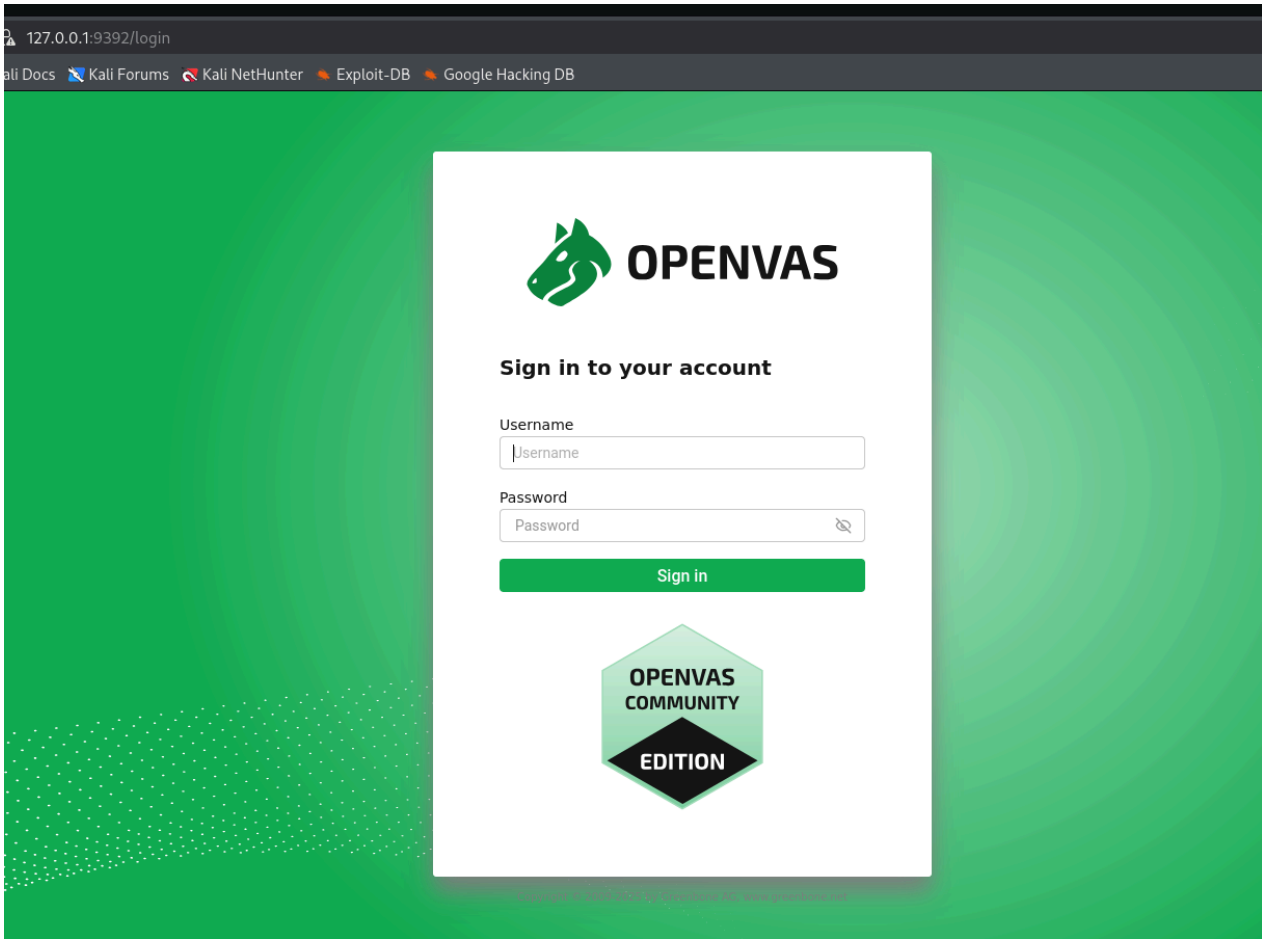
Despite having fewer services than Metasploitable 2, the presence of web, database, and remote access services still created a considerable attack surface. These observations demonstrate that even though the DVWA application is intentionally vulnerable, it is important to apply strict security measures to web applications, their backend services and the whole environment.



SS14: DVWA Port and Service Scan From Kali Linux

4.3 OpenVAS Vulnerability Scanning Results

In this subsection, the results of the vulnerability scans performed with OpenVAS are described. The scans were carried out to reveal the already existing security vulnerabilities that would be associated with the services as well as the configurations found during the Nmap evaluation. OpenVAS risk classifies vulnerabilities according to their severity which makes it easier to prioritize security risks.



SS15: OpenVas Running in Kali Linux

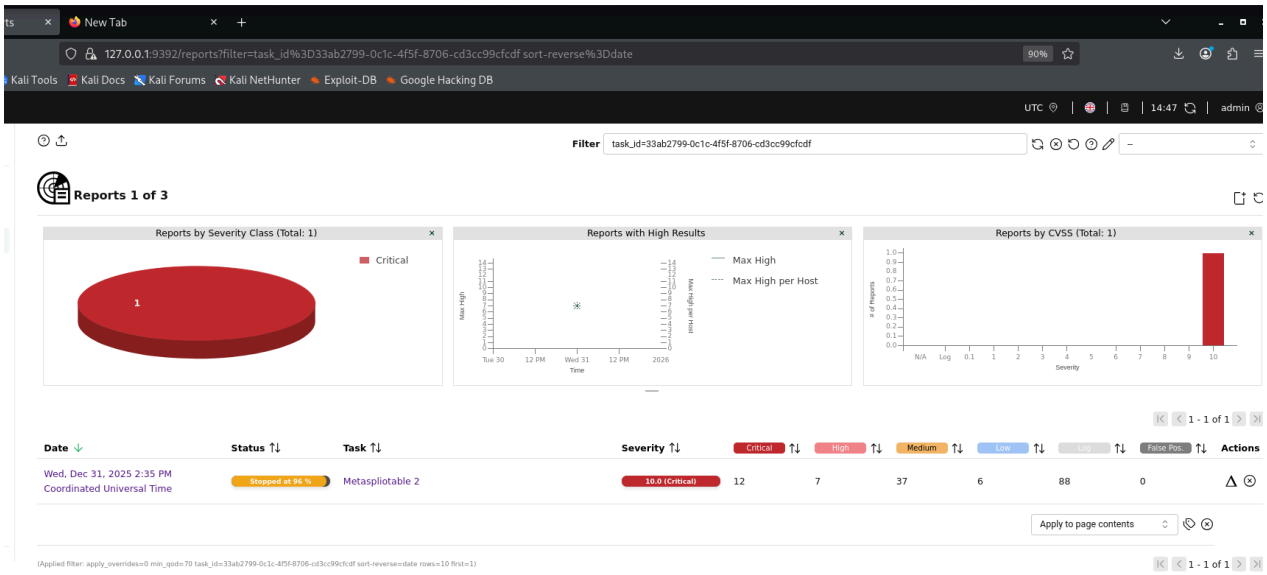
4.3.1 Metasploitable 2 – OpenVAS Results

The OpenVAS scanning of the Metasploitable 2 system disallowed many vulnerabilities, including a large variety of high-severity findings. Outdated services, insecure configurations, and exposed network services are the main reasons for these vulnerabilities. The results support that Metasploitable 2 is a high-risk system for penetration testing demonstrations. The below are some of the vulnerabilities found in the system.

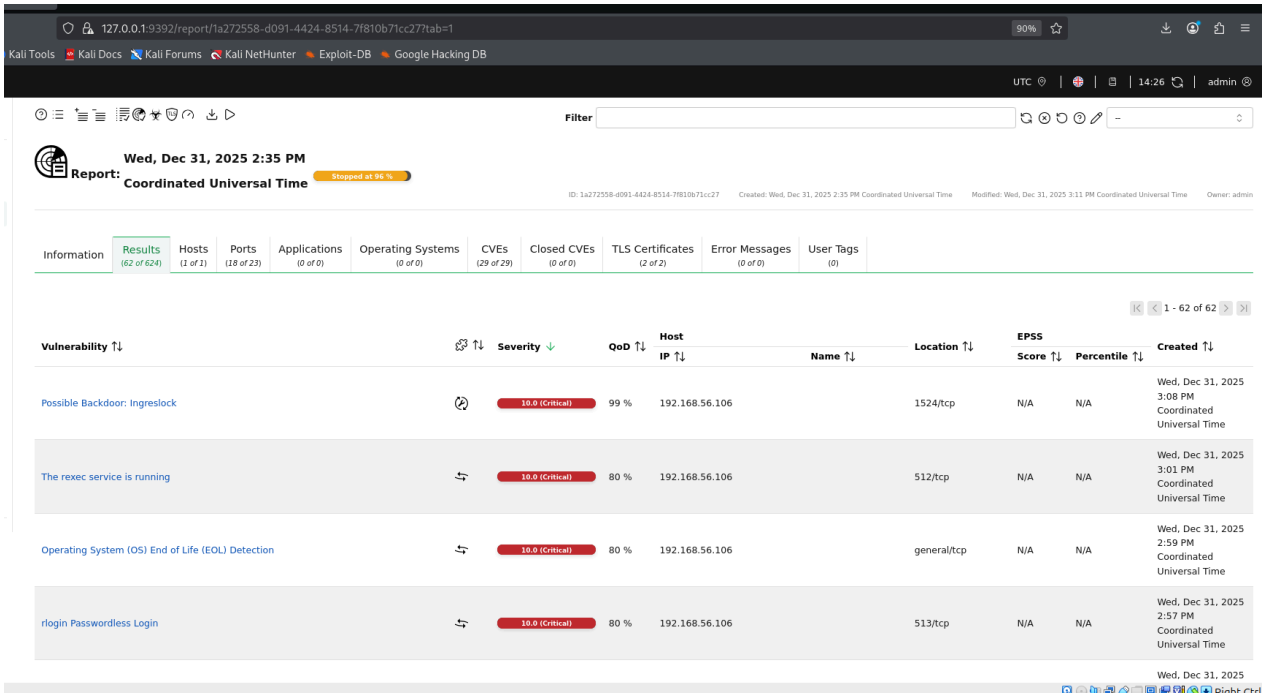
Vulnerability Severity Summary:

Vulnerability	Severity
Possible Backdoor: Ingreslock	Critical
The rexec service is running	Critical
Operating System (OS) End of Life (EOL) Detection	Critical
rlogin Passwordless Login	Critical
FTP Brute Force Logins With Default Credentials Reporting	High
TWiki Cross-Site Request Forgery Vulnerability (Sep 2010)	Medium
Weak MAC Algorithm(s) Supported (SSH)	low

Table 3: Vulnerability Severity Summary for Metaspliotable 2



SS16: Metaspliotable 2 Vulnerability Scan with OpenVas Report



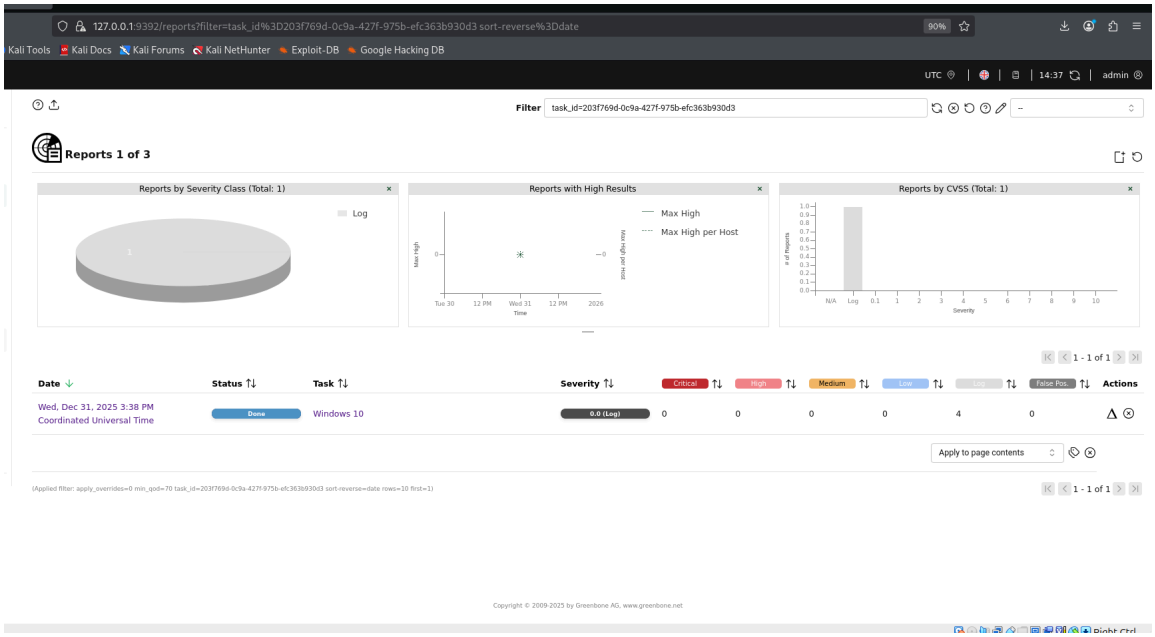
SS17: Metaspliotable 2 Vulnerability Scan with OpenVas Result

4.2.3 Windows 10 with WebGoat – OpenVAS Results

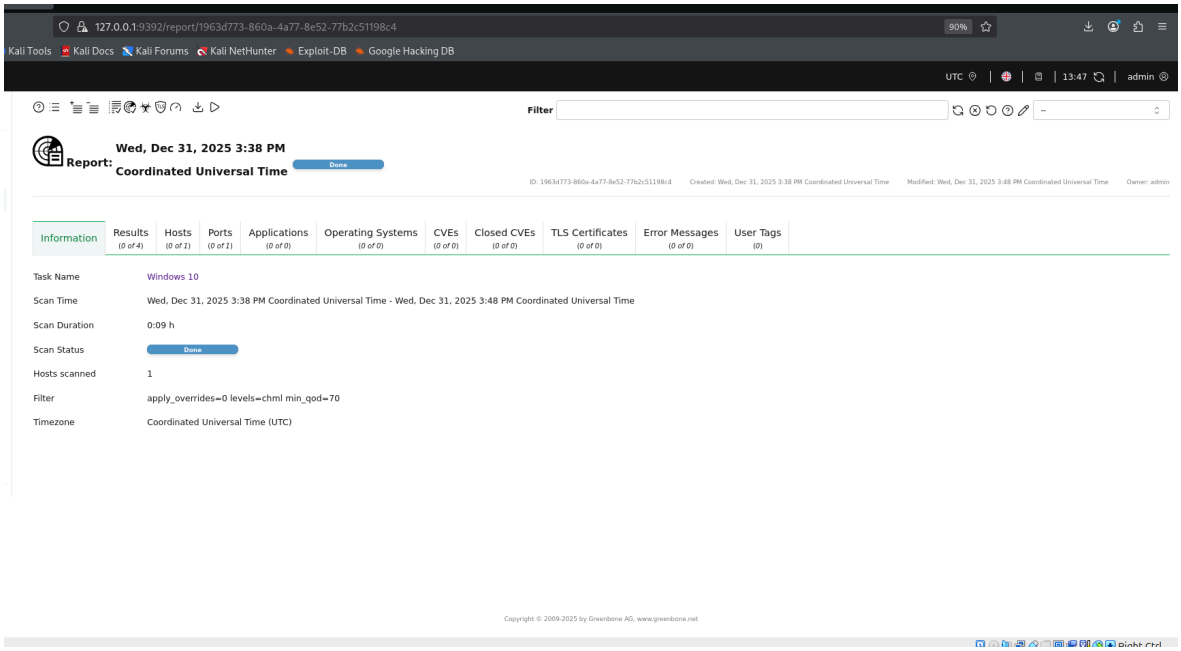
OpenVAS's vulnerability scan of the Windows 10 system revealed no vulnerabilities that were considered necessary to report. The scan result is in agreement with the previous Nmap results which suggested that most of the system's TCP ports were filtered and there were no application services made visible during the scan from outside. The limitation of OpenVAS's ability to reveal potential security breaches was due to the lack of network services, as it depended entirely on the visibility of services for vulnerability detection.

Moreover, the WebGoat application is purposely built to showcase application-level security flaws, which can only be detected through manual testing and the interaction of the tester with the system. The OpenVAS automated scanning tools are not able to find these types of vulnerabilities always, especially if the application is not network accessible. This scenario underlines the limitation of the automated scanners and again

indicates the necessity of combining the network-based vulnerability assessment with the application-level security testing.



SS18: Windows 10 Vulnerability Scan with OpenVas Report



SS19: Windows 10 Vulnerability Scan with OpenVas Result

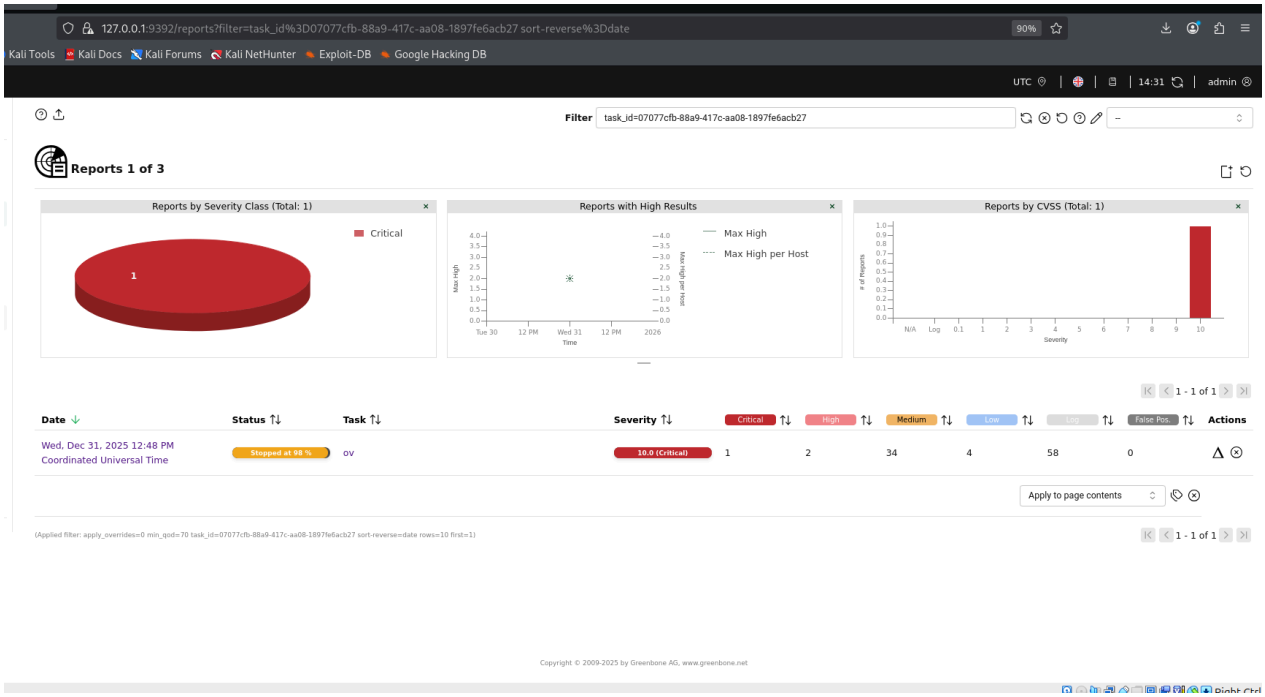
4.2.3 DVWA Virtual Machine – OpenVAS Results

The OpenVAS scan on the DVWA virtual machine found a number of vulnerabilities that were related to the web and database services that were already exposed. Among these vulnerabilities were obsolete web server components and possible misconfigurations concerning database access. The findings were in smaller quantities compared with those of Metasploitable 2 but still the identified problems represented significant security risks in the environment. The below are some of the vulnerabilities found in the system.

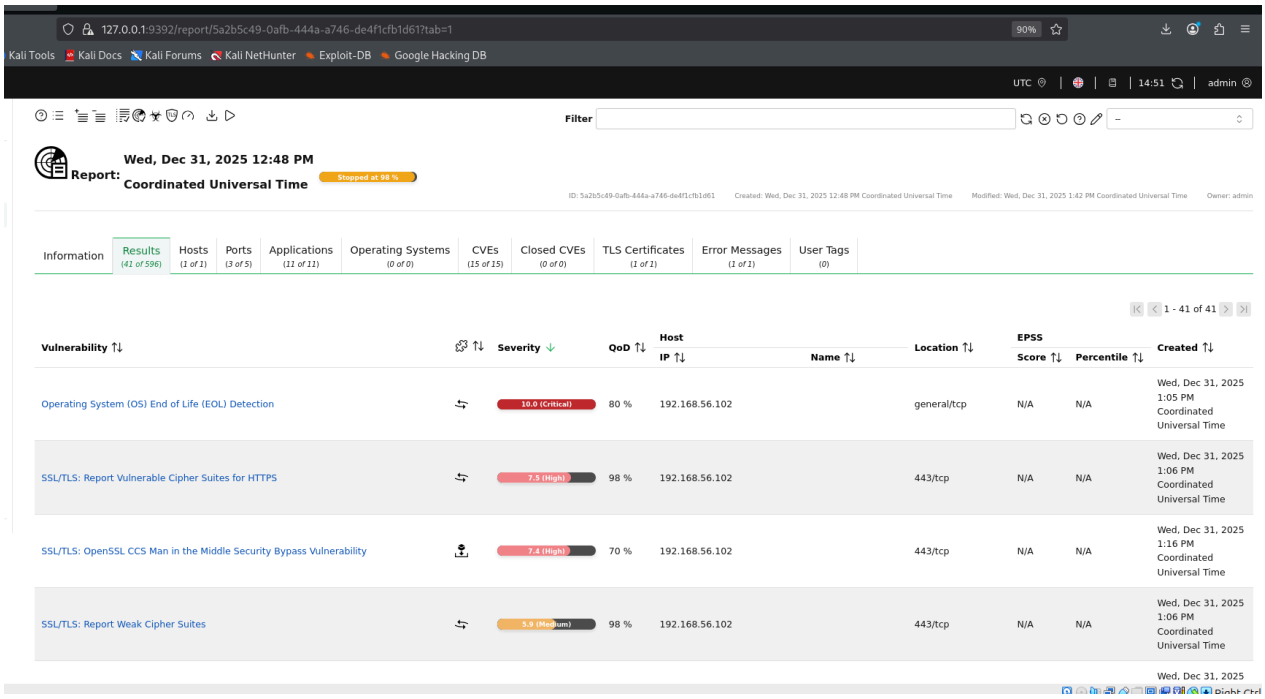
Vulnerability Severity Summary:

Vulnerability	Severity
Operating System (OS) End of Life (EOL) Detection	Critical
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	High
SSL/TLS: OpenSSL CCS Man in the Middle Security Bypass Vulnerability	High
SSL/TLS: Report Weak Cipher Suites	Medium
phpMyAdmin Setup '$host' Variable Cross Site Scripting Vulnerability	Medium

Table 4: Vulnerability Severity Summary for DVWA



SS20: DVWA Vulnerability Scan with OpenVas Report



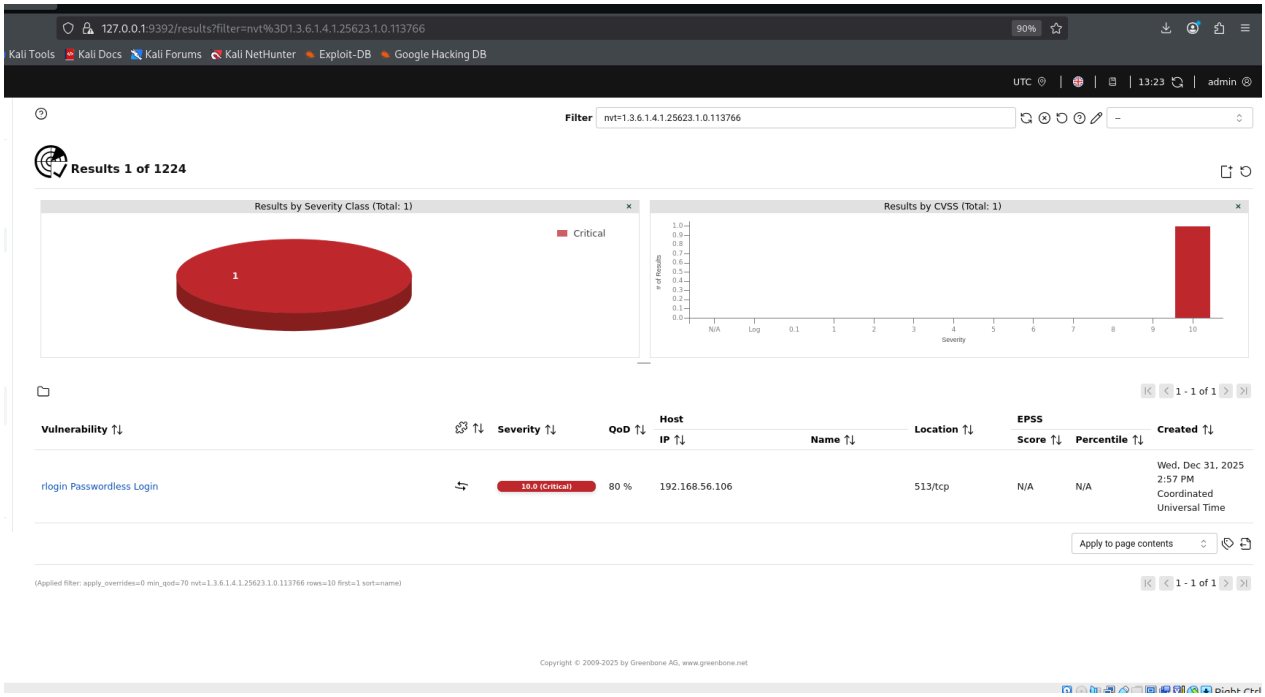
SS21: DVWA Vulnerability Scan with OpenVas Result

5. Vulnerability Analysis & Mitigation

5.1 Vulnerability Description – rlogin Passwordless Login

In the course of the vulnerability assessment of the Metasploitable system, one of the vulnerabilities which carry a very high risk was that of the rlogin service which was detected on TCP port 513 at IP address 192.168.56.106. The fault, OpenVAS found it as rlogin Passwordless Login (OID: 1.3.6.1.4.1.25623.1.0.113766) and designated the flaw, permits the attacker to access the system as root without the need for any form of authentication.

Rlogin service is a part of a bunch of old remote access services called r-services. These services use trust-based authentication methods which are considered insecure, instead of secure password-based or cryptographic authentication. Consequently, if rlogin is misconfigured or allows access, it can give unauthorized users the ability to login to the system without any credentials being validated.



SS22: Most Critical Vulnerability from overall scan with OpenVas

5.2 Potential Impact

This vulnerability carries a critical impact. An attacker that succeeds in exploiting it would be able to take over the impacted system completely with full administrative (root) control. Having root access, an attacker could perform many actions such as installing malware, changing system settings, accessing confidential information, or making the compromised system a gateway for further attacks in the network.

The exploitation of this vulnerability in a real-world organizational scenario might lead to a total compromise of the system, resulting in data leaks, downtime, and losing the customers' trust. The vulnerability is, therefore, assigned a high-risk classification, which necessitates an urgent fix.

5.3 Exploitation Overview

The vulnerability is undeniably due to an antiquated, unsecured, passwordless rlogin service. The flaw can be exploited by the hackers through connecting to the rlogin

service and gaining access using invalid login credentials. The absence of proper authentication controls renders this flaw extremely perilous as it requires only minimal effort or skills to take advantage of it.

The OpenVAS test confirmed that it was possible to obtain root access without a password, hence alerting the system to be very vulnerable and unprotected.

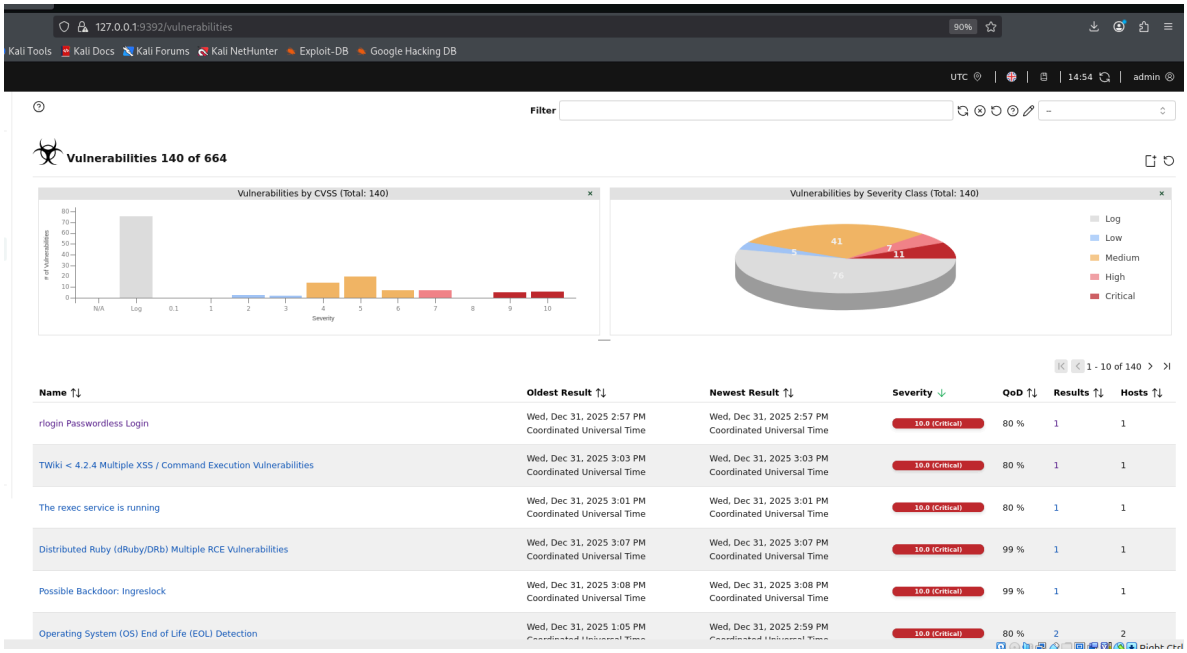
5.4 Mitigation and Recommendations

The recommendation for handling this vulnerability goes as follows:

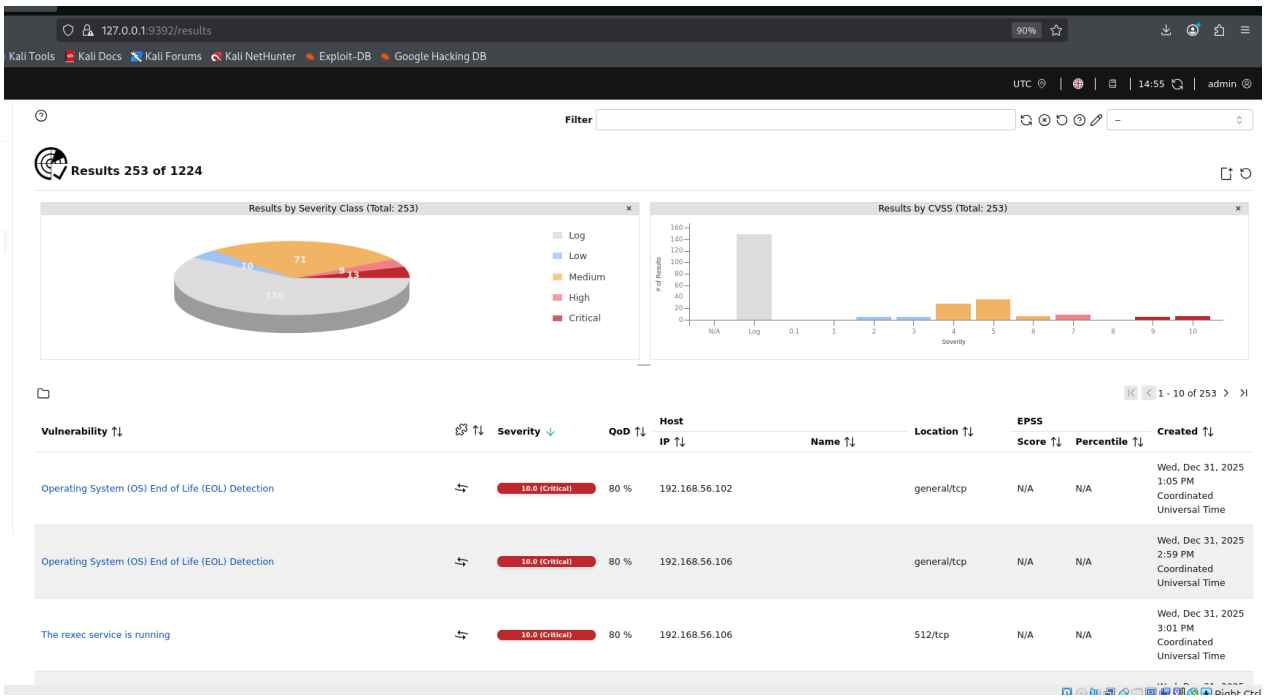
- Shut down the rlogin and other r-services (like rsh and rexec) completely as they are now considered outdated and highly insecure.
- To eliminate the old remote access services, switch to a secure method, for instance, SSH which offers encrypted communication and authentication through strong credentials.
- System hardening practices have to be followed, for example, eliminating unused services and conducting process audits regularly.
- Firewall policies should be made such that traffic through non-essential ports is stopped, port 513 included, thus preventing the system from being too inviting to the hackers.
- Vulnerability scans and assessments should be done regularly because that is the only way to ensure the weaknesses are found and fixed early.

5.5 Relevance to SOA Enterprises, Inc.

For SOA Enterprises, Inc., a passwordless root login vulnerability is a very serious security risk. In case the vulnerability was in production, it would be very easy for the attackers to take control of the critical systems. This means that the security measures like disabling old services, strong authentication controls, and a good security posture need to be in place. Such vulnerabilities should be dealt with in a manner that ensures that the organization systems, data, and operations are not affected.



SS23: Overall Vulnerabilities from overall scan with OpenVas within 3 system



SS24: Overall Vulnerabilities from overall scan with OpenVas within 3 system Result

6. Incident Response Considerations

In cases of a security incident related to the critically dangerous flaw like passwordless root access, SOA Enterprises, Inc. will have to apply a methodical incident response process. First, the incident would be detected and verified through the identification process, which would then be followed by containment actions such as cutting off the affected system from the network to stop further unauthorized access right away. During the containment phase, the vulnerable services including legacy r-services would be disabled.

After the containing of the incident, the next step should be the carrying out of an investigation to find out the totality and effect of the compromise. This will involve system logs going through, and the question of whether there was access to or alteration of data will be answered, and the attacker will be revealed if he had set up any foothold. After the thorough investigation, the system will be made secure again by the means of patching, service hardening, and changing the configurations. Eventually, the whole incident response process will cover the aspect of lessons learned, so as to prevent the occurrence of similar vulnerabilities in the future by better monitoring, staff training, and regular security assessments.

7. Legal, Ethical and Professional Considerations

All penetration testing activities that are part of this assessment were completely executed inside a friendly and authorized laboratory environment. Ethical security testing always obtains prior explicit consent before proceeding with scanning or testing systems. It also requires the application of techniques that would not cause any damage, disruption or unauthorized data access. Just as in real-life situations, penetration testing needs to be done following relevant laws such as the Computer Misuse Act and data protection laws including the handling of sensitive or personal data.

Security professionals are expected to act young and professional at all times. They should responsibly report vulnerabilities, protect confidential information and ensure that

the findings are communicated to the stakeholders in a clear manner. Assertions of ethical conduct and legal compliance are vital to the maintenance of trust and to the security assessments being perceived as contributing positively to the organizational security rather than creating an additional risk.

8. Conclusion

The security assessment also identified the need to employ preventative security controls like vulnerability analysis and penetration testing to introduce the areas of weakness within the network of the company. Various tools like the Nmap and OpenVAS were used to probe various systems and also expose various degrees of exposure amongst the various platforms. Windows 10 system in particular was observed to have few vulnerabilities and network level but on the other hand, the Metasploitable system, was observed to have very weak settings that included a critical vulnerability that allowed one to be able to log in without a password.

The analysis identifies the risk of using old services and low authentication and the restriction of the security evaluation procedure to automated tools as the only ones. The evaluation concludes that a comprehensive security plan is needed including secure configuration, periodic vulnerability testing, incidence response preparedness, and ethical security measures as a means of offering sufficient protection against the threats of IT systems and data within the organizations.

9. References

Greenbone (2023) *OpenVAS vulnerability scanning*. Available at: https://www.greenbone.net (Accessed: 30 December 2025).

Lyon, G.F. (2024) *Nmap network scanning: The official Nmap project guide*. Available at: https://nmap.org/book/ (Accessed: 30 December 2025).

NIST (2018) *Framework for Improving Critical Infrastructure Cybersecurity*. National Institute of Standards and Technology. Available at: https://www.nist.gov/cyberframework (Accessed: 30 December 2025).

OWASP (2021) *OWASP Top Ten Web Application Security Risks*. Available at: https://owasp.org/www-project-top-ten/ (Accessed: 30 December 2025).

Scambray, J., McClure, S. and Kurtz, G. (2011) *Hacking Exposed: Network Security Secrets & Solutions*. 7th edn. New York: McGraw-Hill.

Stallings, W. (2018) *Effective Cybersecurity: A Guide to Using Best Practices and Standards*. Boston: Addison-Wesley.